

Security+ 4.6 · Password Security

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.6 — Password Security (6:22)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Password: COMPRIMENTO > complexidade (14+ é melhor); password manager (gera forte, guarda cifrado); passwordless (FIDO2/YubiKey, biometria, Magic link) = o futuro; NIST: sem troca forçada (incentiva fraca).

Highlights que a prova cobra

- Comprimento > complexidade (14 chars simples > 8 complexos)
- FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing

Dicas de prova & Cenários Típicos

- 'length over complexity'=NIST 800-63B guidance

Cenário clássico de exame: 'senha de 16 chars simples é melhor que 10 chars complexos'=NIST guidance.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.6 — Password Security)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **FIDO2:** Padrão aberto de autenticação sem senha (passwordless) baseado em criptografia de chave pública e biometria/chaves de segurança física (WebAuthn).
- **MFA:** Multi-Factor Authentication: Autenticação multifator exigindo dois ou mais fatores distintos das categorias: algo que você sabe, algo que você tem, algo que você é, algo que você faz ou algum lugar onde você está.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?

- A)** Senha, PIN e resposta secreta
- B)** Algo que sabe, algo que tem, algo que é
- C)** 3 senhas diferentes
- D)** Usuário, senha e e-mail

2. MFA exige pelo menos dois fatores de autenticação. Qual combinação representa autenticação de múltiplos fatores genuína?

- A)** Senha + PIN
- B)** Senha + Token físico
- C)** Dois tipos de biometria
- D)** Pergunta de segurança + Senha

3. A forma correta de ARMAZENAR senhas de usuários:

- A)** Hash com salt (ex: bcrypt)
- B)** Criptografia AES reversível
- C)** Texto claro protegido por firewall
- D)** Base64

4. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'Comprimento > complexidade (14 chars simples > 8 complexos)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Comprimento > complexidade (14 chars simples > 8 complexos)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'length over complexity'=NIST 800-63B guidance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'length over complexity'=NIST 800-63B guidance...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'senha de 16 chars simples é melhor que 10 chars complexos'=NIST guidance.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'senha de 16 chars simples é melhor que 10 chars complexos'=NIST guidance....

8. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'Comprimento > complexidade (14 chars simples > 8 complexos)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Comprimento > complexidade (14 chars simples > 8 complexos)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Password Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'length over complexity'=NIST 800-63B guidance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'length over complexity'=NIST 800-63B guidance...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Algo que sabe, algo que tem, algo que é.

✓ **Por que está certa:** A autenticação multifator (MFA) exige a combinação de pelo menos dois fatores de categorias distintas. As três categorias clássicas são: algo que você sabe (conhecimento, como senha ou PIN), algo que você tem (posse, como token físico ou aplicativo gerador de código) e algo que você é (inerência, como impressão digital ou reconhecimento facial). A opção 'Algo que sabe, algo que tem, algo que é' é a única que elenca corretamente essas três categorias, conforme definido pelo NIST SP 800-63 e pelo CompTIA Security+ SY0-701. MFA é um controle de acesso que mitiga riscos de comprometimento de credenciais, pois um atacante precisaria superar múltiplas barreiras independentes.

✗ **Por que as outras estão erradas:**

- *Senha, PIN e resposta secreta:* Senha, PIN e resposta secreta são todos exemplos de 'algo que você sabe' (fator de conhecimento). Embora sejam mecanismos de autenticação, eles pertencem à mesma categoria, portanto não constituem MFA verdadeiro. O uso de múltiplos segredos do mesmo tipo é chamado de autenticação multi-passo ou multifator aparente, mas não atende à exigência de categorias distintas. Além disso, respostas secretas são frequentemente vulneráveis a ataques de engenharia social e podem ser descobertas, não oferecendo o mesmo nível de segurança que um segundo fator de categoria diferente.
- *3 senhas diferentes:* Três senhas diferentes continuam sendo apenas um fator de conhecimento. A repetição de senhas não adiciona uma nova categoria de autenticação; apenas aumenta a complexidade da mesma categoria. Isso não é MFA, pois um atacante que comprometa o mecanismo de captura de senhas (por exemplo, keylogger ou phishing) pode obter todas as três. A segurança não é multiplicada pela quantidade de senhas, mas pela diversidade de fatores. O CompTIA Security+ enfatiza que MFA requer fatores de tipos diferentes, não múltiplas instâncias do mesmo tipo.
- *Usuário, senha e e-mail:* Usuário e e-mail são identificadores, não fatores de autenticação. O nome de usuário e o endereço de e-mail são públicos ou facilmente descobertos e não provam identidade. A senha é um fator de conhecimento, mas os outros dois não são fatores de autenticação. Portanto, essa combinação não representa MFA. Além disso, o e-mail pode ser usado como canal para envio de códigos, mas por si só não é um fator; ele é um meio de transporte. A definição formal de MFA exige que cada fator seja de uma categoria diferente (conhecimento, posse, inerência), e aqui só há um fator real.

2) B — Senha + Token físico.

✓ **Por que está certa:** A combinação ****Senha + Token físico**** representa autenticação de múltiplos fatores genuína porque combina dois fatores distintos: algo que você sabe (a senha) e algo que você possui (o token físico, como um smart card, chave USB ou dispositivo gerador de OTP). O MFA requer a combinação de pelo menos dois dos três fatores clássicos: conhecimento (algo que você sabe), posse (algo que você tem) e inerência (algo que você é). No syllabus da CompTIA Security+ (SY0-701), essa distinção é fundamental para evitar falsos MFA, como senha + PIN, que são ambos do mesmo fator (conhecimento).

✗ **Por que as outras estão erradas:**

- *Senha + PIN:* Senha e PIN são ambos baseados em conhecimento; ou seja, representam o mesmo fator de autenticação (algo que você sabe). Mesmo que sejam dois segredos diferentes, não configuram MFA genuíno, pois não há combinação de fatores distintos. Um atacante que obtiver ambos (por exemplo, via keylogger ou engenharia social) compromete a autenticação. Para ser MFA, é necessário adicionar um fator de posse ou inerência. Portanto, essa opção é incorreta.

- *Dois tipos de biometria*: Dois tipos de biometria (por exemplo, impressão digital e reconhecimento facial) pertencem ao mesmo fator: inerência (algo que você é). Embora sejam métodos distintos, não constituem MFA genuíno, pois não combinam fatores diferentes. O MFA exige a combinação de categorias distintas (conhecimento, posse, inerência). Além disso, biometrias podem ser problemáticas se comprometidas (uma vez vazadas, não podem ser alteradas). Logo, essa opção não atende ao requisito de múltiplos fatores.
- *Pergunta de segurança + Senha*: Perguntas de segurança e senha são ambos baseados em conhecimento (algo que você sabe). A pergunta de segurança é frequentemente usada como um segundo passo, mas ainda pertence ao mesmo fator. Portanto, não é MFA genuíno. Além disso, perguntas de segurança são vulneráveis a ataques de engenharia social e podem ser descobertas em redes sociais. Para ser MFA, seria necessário adicionar um fator de posse ou inerência. Assim, essa combinação está incorreta.

3) A — Hash com salt (ex: bcrypt).

✓ **Por que está certa:** O armazenamento seguro de senhas de usuários exige o uso de funções de hash criptográfico lentas e resistentes a ataques de força bruta, como bcrypt, scrypt ou Argon2, combinadas com um salt único e aleatório por usuário. O salt impede ataques de tabela pré-computada (rainbow tables) e garante que senhas iguais produzam hashes diferentes. Funções como bcrypt são projetadas para serem computacionalmente custosas, ajustáveis por fator de custo, dificultando ataques de dicionário e força bruta offline. O hash é unidirecional, então mesmo que o banco de dados seja comprometido, o atacante não obtém a senha original diretamente, apenas o hash, que deve ser quebrado individualmente.

✗ **Por que as outras estão erradas:**

- *Criptografia AES reversível*: AES é uma cifra simétrica reversível: com a chave correta, o texto cifrado pode ser decifrado de volta ao texto claro. Se as senhas forem armazenadas cifradas com AES, qualquer pessoa que obtenha a chave de criptografia (por exemplo, através de comprometimento do servidor de aplicação ou do banco de dados) pode recuperar todas as senhas originais. Isso viola o princípio de que nem mesmo os administradores do sistema devem conhecer as senhas dos usuários. Além disso, a gestão da chave AES adiciona complexidade e risco desnecessários para um dado que nunca precisa ser recuperado em texto claro.
- *Texto claro protegido por firewall*: Armazenar senhas em texto claro significa que elas estão legíveis no banco de dados ou arquivo de configuração. Um firewall protege contra acessos não autorizados pela rede, mas não impede que um atacante que explore uma vulnerabilidade na aplicação, um insider malicioso ou um administrador com acesso ao banco de dados leia diretamente as senhas. A segurança em profundidade exige que o dado sensível seja protegido em repouso, independentemente de controles perimetrais. Firewall é um controle de rede, não de armazenamento de credenciais.
- *Base64*: Base64 é uma codificação reversível sem chave, frequentemente usada para representar dados binários em texto. Não oferece confidencialidade alguma: qualquer pessoa pode decodificar uma string Base64 instantaneamente. Armazenar senhas em Base64 é funcionalmente equivalente a armazená-las em texto claro, apenas com uma aparência ofuscada. Não há salt, não há custo computacional e não há resistência a ataques. É uma prática completamente inadequada para proteção de credenciais.

4) A — Implementar a solução correspondente: Comprimento > complexidade (14 chars simples > 8 complexos)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): Comprimento > complexidade (14 chars simples > 8 complexos).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'length over complexity' = NIST 800-63B guidance....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): 'length over complexity' = NIST 800-63B guidance.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: 'senha de 16 chars simples é melhor que 10 chars complexos' = NIST guidance.....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): 'senha de 16 chars simples é melhor que 10 chars complexos' = NIST guidance..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Comprimento > complexidade (14 chars simples > 8 complexos)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): Comprimento > complexidade (14 chars simples > 8 complexos).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: 'length over complexity'=NIST 800-63B guidance....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): 'length over complexity'=NIST 800-63B guidance.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola

frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.